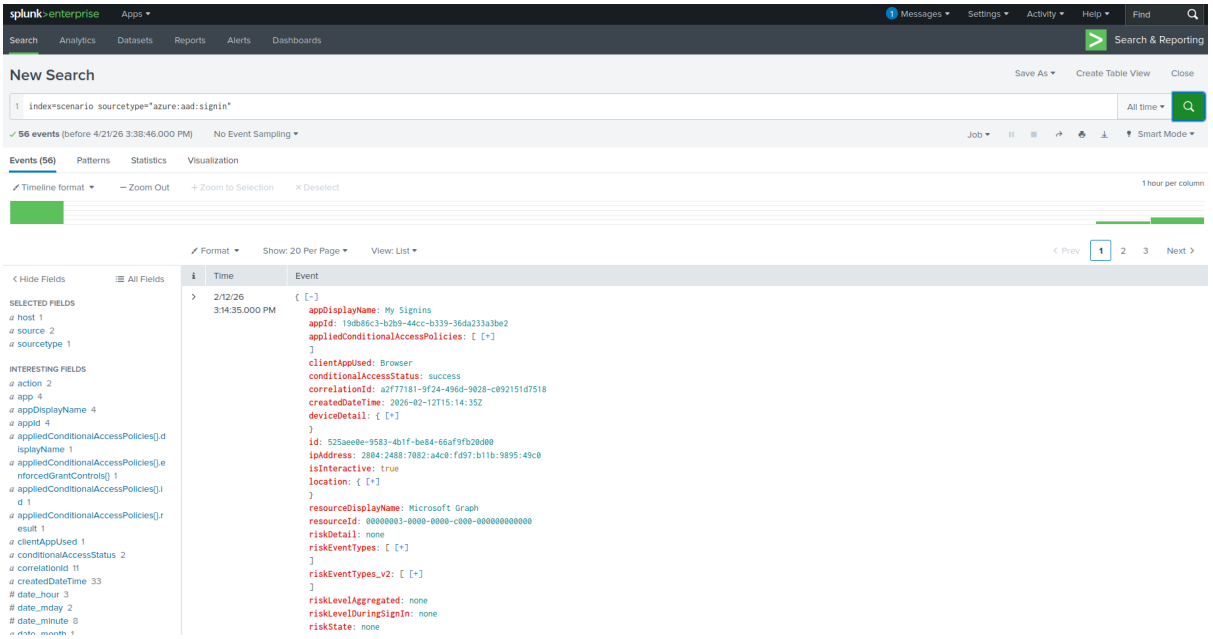
Simulação de um cenário clássico de ataque de força bruta + comprometimento de conta dentro do Splunk Enterprise Security usando logs do Microsoft Entra ID

Irei analizar os Logs dos logins feitos para identificar um possível invasor.

Filtrei os logs digitando esse comando em search:

index=scenario sourcetype="azure:aad:signin"

Do lado direito configurei para “All time”, existem várias opções, como ultimas 24 horas, ultimos 15 minutos etc. Apareceram vários resultados de login.



Filtrei por falhas de login usando esse comando:

index="scenario" sourcetype="azure:aad:signin" "status.errorCode"!=0

| stats count as event_count values(ipAddress) as ip_addresses

values(appDisplayName) as applications values(status.errorCode) as errorCodes by userPrincipalName

| sort - event_count

| table applications, userPrincipalName, ip_addresses, errorCodes, event_count

Foi mostrado algumas informações como:

Aplicativo usado: OfficeHome

Email: allan.smith@finegalo.thm

IP: 2804:2488:7082:a4c0:fd97:b11b:9895:49c0

Códigos de erro: 50126 e 50140.

Pesquisei os códigos de erro no site da Microsoft:

https://login.microsoftonline.com/error

Os significado dos códigos de erros foram esses:

50126: Nome de usuário ou senha inválido

50140: Isso ocorreu devido à interrupção de ‘Mantenha-me conectado’ quando o usuário estava entrando.

Um IP tentando várias vezes com erro = possível **brute force / password spraying**

Listei todos os logins bem-sucedidos a partir do IP descoberto:

```
index=scenario sourcetype="azure:aad:signin" "status.errorCode"=0
ipAddress="2804:2488:7082:a4c0:fd97:b11b:9895:49c0"
| stats values(ipAddress) as ip_addresses values(appDisplayName) as applications
by userPrincipalName
| table applications, userPrincipalName, ip_addresses
```

Percebi que o IP que estava errando o login conseguiu entrar

Conclusão do ataque

O que aconteceu foi:

Etapas do ataque:

1. Atacante escolhe um usuário
2. Faz várias tentativas de senha (força bruta)
3. Eventualmente acerta a senha
4. Consegue acessar a conta
5. Começa a usar os serviços (apps)

Investigação

Após confirmar que a conta foi comprometida, investiguei para identificar as alterações feitas pelo invasor.

Usei aqui o Audit Logs (Logs de auditoria). Os logs de auditoria registram ações administrativas e alterações feitas no ambiente Entra ID.

Usei esse comando para analisar:

```
index=scenario sourcetype="azure:aad:audit"
```

ormat ▾ Show: 20 Per Page ▾ View: List ▾

Time	Event
2/12/26 3:16:40.764 PM	{ [-] activityDateTime: 2026-02-12T15:16:40.7646586Z activityDisplayName: Update StsRefreshTokenValidFrom Timestamp additionalDetails: [[+]] category: UserManagement correlationId: fd152a3e-a1ef-45c7-8c4f-ac5ad871c1ee id: Directory_fd152a3e-a1ef-45c7-8c4f-ac5ad871c1ee_QYCW5_402711012 initiatedBy: { [+] } loggedByService: Core Directory operationType: Update result: success resultReason: targetResources: [[+]] } Show as raw text host = ce-splunk | source = /opt/splunk/var/spool/splunk/37c889f2284950be_5cf4a99e00b6ccab_events.... | sourcetype = azure:aad:audit
2/12/26 3:16:40.762 PM	{ [-] activityDateTime: 2026-02-12T15:16:40.7626585Z activityDisplayName: Reset user password additionalDetails: [[+]] category: UserManagement

Várias informações do que foi feito aparecem após o comando.

Realizei uma consulta com o email da conta comprometida usando esse comando:

index=scenario sourcetype="azure:aad:audit" targetResources{}.userPrincipalName="allan.smith@finegalo.thm"

| eval initiator=coalesce('initiatedBy.user.userPrincipalName', 'initiatedBy.app.displayName')

| sort - _time

| table _time, initiator, activityDisplayName, result, targetResources{}.userPrincipalName

2026-02-12 15:16:40.764	Microsoft password reset service	Update StsRefreshTokenValidFrom Timestamp	success	allan.smith@finegalo.thm
2026-02-12 15:16:40.762	Microsoft password reset service	Reset user password	success	allan.smith@finegalo.thm
2026-02-12 15:16:40.760	allan.smith@finegalo.thm	Reset password (self-service)	success	allan.smith@finegalo.thm
2026-02-12 15:16:40.676	Microsoft password reset service	Update PasswordProfile	success	allan.smith@finegalo.thm
2026-02-12 15:16:40.671	Microsoft password reset service	Update user	success	allan.smith@finegalo.thm
2026-02-12 15:16:40.581	Microsoft password reset service	Update PasswordProfile	success	allan.smith@finegalo.thm
2026-02-12 15:16:40.484	allan.smith@finegalo.thm	User started password reset	success	allan.smith@finegalo.thm
2026-02-12 14:57:46.039	allan.smith@finegalo.thm	Reset password (self-service)	success	allan.smith@finegalo.thm
2026-02-12 14:51:26.338	Azure Credential Configuration Endpoint Service	Update user	success	allan.smith@finegalo.thm
2026-02-12 14:51:25.369	Azure MFA StrongAuthenticationService	Update user	success	allan.smith@finegalo.thm
2026-02-12 14:51:17.000	allan.smith@finegalo.thm	User started security info registration	success	allan.smith@finegalo.thm
2026-02-11 18:17:09.748	Office 365 SharePoint Online	Update user	success	allan.smith@finegalo.thm
2026-02-11 18:17:09.743	Office 365 SharePoint Online	Update user	success	allan.smith@finegalo.thm

Aqui percebi pela data e pelo horário que a primeira coisa que ele fez foi:

Em **activityDisplayName:** User started security info registration

O usuário iniciou o registro de informações de segurança.

Usei esse outro comando para listar as alterações realizadas por esse usuário:

index=scenario sourcetype="azure:aad:audit" initiatedBy.user.userPrincipalName="allan.smith@finegalo.thm"

| sort - _time

| table _time, initiatedBy.user.userPrincipalName, activityDisplayName, result, targetResources{}.userPrincipalName

_time	initiatedBy.user.userPrincipalName	activityDisplayName	result	targetResources{}.userPrincipalN
2026-02-12 15:16:40.760	allan.smith@finegalo.thm	Reset password (self-service)	success	allan.smith@finegalo.thm
2026-02-12 15:16:40.484	allan.smith@finegalo.thm	User started password reset	success	allan.smith@finegalo.thm
2026-02-12 15:14:53.344	allan.smith@finegalo.thm	Settings_GetSettingsAsync	success	null
2026-02-12 15:14:38.934	allan.smith@finegalo.thm	Settings_GetSettingsAsync	success	null
2026-02-12 14:57:46.039	allan.smith@finegalo.thm	Reset password (self-service)	success	allan.smith@finegalo.thm
2026-02-12 14:56:55.349	allan.smith@finegalo.thm	Settings_GetSettingsAsync	success	null
2026-02-12 14:51:17.000	allan.smith@finegalo.thm	User started security info registration	success	allan.smith@finegalo.thm
2026-02-12 14:50:16.927	allan.smith@finegalo.thm	Settings_GetSettingsAsync	success	null

Verifiquei que o usuário alterou a senha. Reset password (self-service).

Conclusão

Agora tendo as informações que comprovam o ataque posso acionar a equipe responsável por tomar as providências necessárias.

Olá, eu sou Paulo Cesar, formado em Segurança da Informação. Apresento aqui resultados de prática em Cibersegurança, análise Forense Computacional e OSINT.

Linkedin: https://www.linkedin.com/in/paulo-cesar-security/